Semantic Secrets

Research Description and Technical Direction

Approved v4 direction — 26 October 2026

Central question.

Can an intended semantic credential be reconstructed reliably while related unauthorized alternatives remain distinguishable, and how do perception and normalization affect that balance?

The research direction and documentation update are approved. No P9-v4 phase has started. Before each phase, explain what will be done, how and why, then wait for the author's authorization.

Target: 12th IEEE European Symposium on Security and Privacy, 2027

Internal research-direction synthesis; not a completed experimental paper

Contents

1 Research Goal and Direction **2**

2 Proposed Contributions **2**

3 Scientific Pipeline **2**

4 Dataset and Manual References **3**

5 Normalization and API Strategy **4**

6 Security and Evaluation **4**

7 Phase Roadmap **5**

8 Authorization and Failure Handling **5**

9 Current Status and Historical Integrity **6**

10 Deferred Privacy and Claim Boundaries **6**

11 EuroS&P 2027 and Evidence Readiness **7**

1 Research Goal and Direction

Semantic Secrets retains the long-term goal of reconstructable semantic authentication. The immediate research studies the semantic differences that authentication needs to preserve: object identity, attribute ownership, counts, interactions and spatial relations.

Legitimate reconstruction may change wording, image style or incidental details. However, tolerance can also make an unauthorized alternative acceptable. The study therefore connects perception and normalization errors to a frozen authentication decision. Better extraction F1 alone is insufficient evidence of better authentication.

The present work uses researcher-authored concepts and independently generated visual realizations. It does not involve users reconstructing remembered credentials and cannot establish human recall, memorability, usability, preference, accessibility, natural secret choices or superiority to passwords/passkeys.

The working paper title is *Semantic Secrets: Reconstruction and Security-Relevant Semantic Distinctions in Visual Authentication.* This is a prospective study, not a validated authentication product.

2 Proposed Contributions

New v4 identifiers avoid rewriting historical C1–C4.

V4-C1: Error-to-authentication methodology
A common pipeline and evaluation framework connecting generation, extraction, normalization and graph errors to reconstruction and unauthorized acceptance.

V4-C2: Semantic distinction evidence
A paired study of which differences survive or collapse across named pipelines and image sources, with binding, coverage, failures and family-level uncertainty.

V4-C3: Reconstruction and attacker outcomes
Independent technical reconstruction and finite-budget attacker success under frozen acceptance rules, explicit knowledge and costs.

These are hypotheses requiring evidence and a focused novelty review. P8's earlier novelty pass concerns its earlier composition; it does not automatically establish novelty for v4. A model leaderboard, graph representation, dictionary, LLM substitution or dataset alone is not the proposed security contribution.

Historical C1 reconstruction and C3 acceptance-region analysis inform the study. Historical C2 mandatory/tolerant policy remains a candidate mechanism, not an assumed winner. Historical C4 private verification remains a separate deferred goal, with its original correctness, leakage and compromise questions intact.

VSA remains the closest-work comparison. Distinguish its semantic-policy component from its complete semantic-plus-password architecture. Image-independent semantic authentication, canonical tokens, quantity rules, conjunction and user-selected policies are not new contributions.

3 Scientific Pipeline

For intended concept C, reconstruction interface P, generator G and randomness r:

$$I = G(P, r), \qquad O = \mathsf{Observe}(I), \qquad S = \mathsf{Compile}(N(O)).$$

Here N is the versioned normalization rule. Compilation yields a graph or typed failure. The prompt is an interface, the image a transient medium, observations probabilistic evidence and the graph the representation used by the predicate. Generated pixels add no credential entropy.

The graph preserves instances, attribute ownership, subject–relation–object roles and counts. Flat arrays lose binding: a red cup with a blue book differs from a blue cup with a red book despite identical word sets.

Initially compare one feasible generative VLM pipeline with one feasible specialized perception pipeline. Grounding DINO and SigLIP2 are also vision-language components; the contrast concerns extraction architecture, not whether language is used. Exact model/API choices remain prospective.

The shared compiler owns schema validation, identifiers, canonical order, duplicate handling and serialization. Reusing v3 code requires interface and correctness review. Changes receive new versions; historical schemas and compiler goldens are preserved.

Define grounding explicitly before implementation. Required boxes must be supplied by all arms or grounding must be reported as a separate task with unsupported cases counted. Never infer geometry from missing boxes. The same public ontology/task context is allowed for every pipeline; intended per-image answers are withheld.

4 Dataset and Manual References

The three image sources answer different questions:

- **Generated naturalistic images** provide primary evidence for the concept-to-image reconstruction workflow.
- **Controlled drawings** isolate individual semantic differences and diagnose failures.
- **Photographs** test external visual generalization, subject to provenance, permission and training-overlap limitations.

A photograph may inspire a manually authored intended concept. Produce its generated variant from the text specification and its drawing from the same intended facts. Direct image-to-image copying is not the primary free-language reconstruction experiment.

Organize families around identity, attribute binding, cardinality, interactions and spatial relations. Examples include dog versus cat beside a car, swapped cup/book colors, one versus two dogs, holding a cup versus standing beside it, and a cat on versus under a chair. These examples are not a frozen corpus.

The project author manually labels the actual visible content of every evaluated image, without perception predictions. Keep intended concepts and observed references separate. If generation produces a bottle instead of the requested cup, correct bottle extraction should receive credit while generation fidelity records the mismatch.

The annotation rubric must define ambiguity, unsupported facts, instance correspondence and negative opportunities. Delayed author self-review is useful but is not independent inter-annotator agreement. No model-generated labels are passed off as author truth.

Keep originals, derivatives, near-duplicates and related unauthorized alternatives in one family partition. Separate development and formal evaluation, and separate capability tuning from final reconstruction/attack targets. Existing inspected v3 images default to development/diagnostic material pending an exposure audit. The twelve sealed v1 families remain sealed.

5 Normalization and API Strategy

The primary normalization arm uses deterministic formatting and reviewed, frozen mappings. An LLM may suggest mappings during development, but review must distinguish aliases from abstractions and senses. In context, cat/kitty may be equivalent; cat/dog to animal deliberately removes a credential distinction.

An optional live LLM arm changes normalization only on the same cached observations. It cannot see intended answers, supply reference truth or add image facts. Measure correct mappings, false merges/splits, abstention, unsupported output and repeatability, followed by acceptance effects. Temperature zero is not proof of hosted determinism.

Use approved APIs first on public or safely authorized non-secret fixtures. Do not rent GPUs or run local models in the immediate programme. A model name or public demo does not prove stable API availability, exact checkpoint identity, required output support or license compatibility.

Before calls, approve endpoints, disclosed inputs, request schema, model identity, cost/call limits and bounded retries. Preserve raw requests/responses and hashes, timestamps, requested versus attested settings, failures, parse events, costs and observed latency. Repeating a hosted request tests service stability; replaying cached output tests downstream determinism.

If a required API is unavailable, explain compatible hosted alternatives with new identities, an explicitly narrower task, or deferral. No silent substitutions. Later local execution requires a separately authorized semantic-parity and performance study. API latency does not establish model-only latency, VRAM or privacy from providers.

6 Security and Evaluation

For frozen policy θ, the acceptance region is

$$\mathcal{A}_\theta(S) = \{S' : \mathsf{Accept}_\theta(S, S') = 1\}.$$

The attacker wins by finding any member, not recovering exact pixels, wording or graph. Algorithms, model identities, vocabulary, canonicalization and thresholds are public.

Separate generation fidelity; extraction precision/recall/F1 and binding; graph validity and typed failure; normalization errors; independent reconstruction; negative acceptance; and finite-budget attacker success. Enforce one-to-one object matching and retain all attempted cases in the defined accounting. API failures, timeouts, abstentions and unsupported tasks cannot disappear from denominators.

Use paired comparisons and family/account uncertainty. Freeze support, sample-size rationale, repeats, exclusions, retries, thresholds and meaningful-effect criteria before formal outputs. Same-image repetition differs from independent reconstruction; selecting cached positive samples because they already match is not a reconstruction trial.

After capability interpretation, separately design the policy and reconstruction evaluation. Compare a justified bounded set of strict semantic, fuzzy overlap and reproducible VSA-style baselines with a system-derived mandatory/tolerant candidate where useful. Fit all choices on permitted development data; unsupported types cannot be promoted by favorable authentication outcomes. A claim about image-stage added value needs a matched direct-text control.

Report enrollment failure, conditional technical FRR and unconditional reconstruction success separately. Random negatives, deliberately close alternatives and adaptive attacks are different distributions.

Knowledge levels range from K0 generic/public information, through K1 source-frequency and K2

partial-target facts, to K3 near-secret information. Freeze the candidate interface, auxiliary data, oracle feedback, budgets, duplicates and generation/extraction/verification costs. Report success at 1, 5, 10 and the approved maximum budget, accounts reached and guesses to success with censored failures. Sampled attacks do not exhaust the accepted region or prove universal security.

7 Phase Roadmap

Every listed phase requires a detailed explanation and separate authorization.

1. **P9-v4A — Design:** resolve exact novelty, API candidates, common tasks, data/reference rules, normalization, metrics and pilot budget. No model calls.
2. **P9-v4B — Engineering:** repair evaluator/path defects and implement the approved common runner, adapters and reference validation with deterministic/mocked checks.
3. **P9-v4C — API pilot:** use author-labeled development fixtures and bounded approved calls to assess support, errors, repeatability and cost.
4. **P9-v4D — Formal freeze:** complete author references, provenance/support/split audits and the capability protocol before formal calls.
5. **P9-v4E — Common comparison:** execute the frozen capability/graph study; report valid positive and negative findings with qualified language.
6. **P10-v4A/B — Reconstruction:** separately design/develop/freeze policies and fresh trials, then authorize and execute held-out evaluation.
7. **P11-v4A/B — Attacks:** separately design/freeze attackers and budgets, then authorize and execute their evaluation.
8. **P17-v4 — Analysis:** consolidate evidence, uncertainty, novelty and claim support; obtain the author's final scope decision.
9. **P18-v4/P19-v4/P20-v4:** complete the evidence-backed manuscript, artifact and submission audit under their own approvals.

Local parity/performance, extra models, live LLM normalization and private-verification construction are separate optional/deferred branches. The full details are in PLAN.md; legacy phase text is archived reference, not current execution permission.

8 Authorization and Failure Handling

Before a phase, explain:

1. what question it answers, why it is needed and what outputs it produces;
2. current evidence, prerequisites, unresolved defects and affected files;
3. ordered methods, models/services, inputs/splits, references and metrics;
4. scope, calls/cost/time estimates, disclosure and retry limits;
5. success/failure criteria and what each outcome can establish;
6. alternatives and the recommended choice.

Then wait for explicit authorization. Direction approval, elapsed time or completion of another phase is not approval. Read-only preparation for an explanation is permitted if it does not execute models, acquire data, expose held-out inputs or incur charges.

If something fails, preserve inputs, logs, responses and configurations. Explain known versus suspected causes and whether the issue is infrastructure/API, code/evaluation, labels/data, output format, semantic capability, statistical support or the research hypothesis.

Offer repairs or alternative strategies, their costs and scientific consequences, and recommend a next step. Obtain authorization before substantive continuation or scope changes. Pause only affected actions when continued execution would corrupt evidence, violate a freeze or exceed approval; a pause is not project termination.

Do not automatically reject the hypothesis, abandon an approach or terminate the project. This does not require endless retries or force positive results. Preserve failed gates, never tune held-out answers, and create a new version and independent evaluation when methodology changes after output.

Measurement validity, constructive viability and publication readiness are different decisions. A valid negative experiment may complete a useful measurement phase while failing a constructive hypothesis. The author decides among explained continuation, narrowing or abandonment options.

9 Current Status and Historical Integrity

As of the 26 October audit:

- P0–P7 remain historical v1 evidence. P6 found poor targeted-neighbor separation; P7 found no material benefit from its tested image pathways.
- P8 passed the earlier scoped novelty review. P9-v2 failed the direct complete-JSON schema requirement by logical futility, not a full semantic accuracy comparison or universal VLM impossibility result.
- P9-v3 methodology, compiler/runtime and v3.0–v3.4 freezes remain intact. The empirical branch is paused.
- The earlier audit reported 421 passing core tests, including 320 compiler cases. These are engineering observations, not model results.
- The v3 dataset contains 240 images and 120 controlled references. Naturalistic references and the final manifest/support/ground-truth freeze remain incomplete. Hosted generator weights/settings are unattested.
- The evaluator's one-to-one matching defect and moved manual root-path defects remain unresolved. This documentation update does not fix or run them.
- No P9-v4 phase, formal accuracy, independent reconstruction, budgeted attack, local resource or private-verification result is established.

Historical code/configurations/results are not retuned or relabeled. The next action is to present the detailed P9-v4A proposal and wait for authorization.

10 Deferred Privacy and Claim Boundaries

The strongest future private design keeps secret-bearing prompts, images, observations, graphs and embeddings on a trusted client. API experiments on public fixtures do not establish that boundary

in a deployed system.

A private branch must define exact functionality and stored records, service/key assumptions, reference-predicate equivalence, template/policy/transcript leakage, database-only candidate testing, linkage, replay and compromise outcomes. Cryptography cannot repair semantic guessability. Hashing, salting or encryption alone proves none of these privacy properties.

No human-subject study, natural-choice entropy estimate, memorability claim, password/passkey superiority or production-ready authentication claim is authorized. Findings must name their tested pipeline, dataset, attack knowledge, budget and limitations.

11 EuroS&P 2027 and Evidence Readiness

The target remains the 12th IEEE European Symposium on Security and Privacy in Madrid, 5–9 July 2027. Mandatory registration is **25 November 2026 AoE**; full-paper submission is **2 December 2026 AoE**. These are separate deadlines. The date-only CFP gives no exact clock time; verify HotCRP before submission.

Use the supplied IEEE A4 template and 13-body-page limit. Keep essential evidence and proactive harm analysis in the body; provide Data Availability and anonymous AI-use acknowledgments. References, appendices and submission acknowledgments are additional. The paper remains an anonymous planning draft.

Internal targets are evidence review on 13 November, registration metadata on 24 November, final audit on 30 November and upload buffer on 1 December. These dates do not authorize phases or waive evidence requirements.

The immediate paper focuses on V4-C1–C3. A valid restricted or negative result can be useful if it is novel, complete and supported. If the cycle is infeasible, explain missing evidence and continuation options. Non-submission does not terminate the research.

Authority: AGENT.md; direction: docs/research_direction_v4.md; workflow: docs/phase_workflow.md; execution sequence: PLAN.md. This synthesis records the approved direction, not completed scientific results.